

Gestión de seguridad de la información

Capítulo 1 - Fundamentos de la Seguridad de la Información

Tendencias en el área de la “gestión de seguridad de información”

La familia ISO 27000 pretende ser una norma dirigida a los responsables de iniciar, implantar o mantener la seguridad de la información de una organización.

La norma ISO 27001 está orientada a establecer, implementar, operar, monitorear, analizar, mantener y mejorar un Sistema de Gestión de Seguridad de la Información.

La norma actualizada ISO-27001 cuenta con 114 controles en 14 categorías o dominios.

La norma ISO-27002 proporciona las directrices para las normas de seguridad de la información de la organización y las prácticas de gestión de seguridad de la información, incluyendo la selección, implementación y gestión de los controles, considerando el entorno de riesgos de seguridad de la información de la organización.

¿Por qué preocuparse por la seguridad?

Problemas comunes:

- Destrucción de la información y otros recursos.
- Modificación o distorsión de información.
- Robo, eliminación o pérdida de información u otros recursos.
- La revelación de información.
- La interrupción de los servicios.

La seguridad de la información es crucial para asegurar la competitividad, la rentabilidad, el cumplimiento de los requerimientos legales y la imagen de la organización en el mercado de las organizaciones.

Definiciones

La seguridad de la información incluye la protección de información, sistemas, recursos y demás activos contra desastres, errores (intencionales o no) y manipulación no autorizada, para reducir la probabilidad y el impacto de los incidentes de seguridad.

La seguridad de la información es la protección de la información contra los diversos tipos de amenazas para garantizar la continuidad del negocio, minimizando los riesgos y maximizando el retorno sobre la inversión y las oportunidades de negocio.

Incidente de seguridad: corresponde a cualquier evento adverso relacionado con la seguridad.

Activo: cualquier elemento que tenga valor para la organización y su negocio.

Amenaza: cualquier evento que explote vulnerabilidades. Causa potencial de un incidente no deseado, que puede resultar en daños a un sistema u organización.

Vulnerabilidad: cualquier debilidad que puede ser explotada y ponga en peligro la seguridad de los sistemas y datos. Fragilidad de un activo o grupo de activos que pueden ser explotados por una o más amenazas. Las vulnerabilidades son fallas que permiten la aparición de deficiencias en la seguridad general del equipo o de la red. A partir de esta falla, las vulnerabilidades son explotadas por amenazas que cuando se materializan, causan daños al computador, a la organización o a los datos personales.

Riesgo: combinación de la probabilidad (oportunidad de que la amenaza se materialice) de que ocurra un evento y sus consecuencias para la organización.

Ataque: cualquier acción que comprometa la seguridad de una organización.

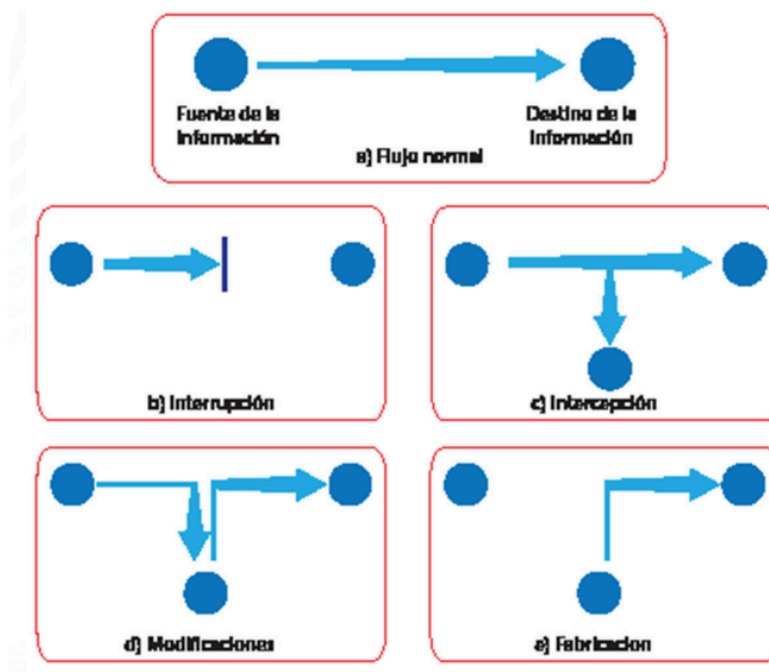
Impacto: resultado evaluado de un evento en particular.

Modelos de ataque

Hay cuatro modelos posibles de ataque:

- **Interrupción:** cuando un activo se destruye o queda indisponible (o inutilizable), caracterizando un ataque contra la disponibilidad.
- **Interceptación:** cuando se accede a un activo por un tercero no autorizado (persona o programa del computador), caracterizando un ataque contra la confidencialidad.
- **Modificación:** cuando se accede a un activo por un tercero no autorizado (persona o programa del computador) y se modifica, materializando un ataque contra la integridad.

- **Fabricación:** cuando una parte no autorizada (persona o programa del computador) inserta objetos falsificados en un activo, configurando un ataque contra la autenticidad.



Formas de ataque

El **ataque** es un acto deliberado de tratar de esquivar los controles de seguridad con el objetivo de explotar las vulnerabilidades. Existen los siguientes tipos de ataque:

- **Ataques pasivos:** ataques basados en escuchar y monitorear las transmisiones, con el fin de obtener la información que se está transmitiendo. Son difíciles de detectar debido a que no implica cambios en los datos, sin embargo, son posibles de prevenir con el uso de la criptografía.
- **Ataques activos:** involucran la modificación de datos, la creación de objetos falsos o negación de servicio, y tienen las propiedades opuestas de ataques pasivos. Difíciles de prevenir debido a la necesidad de una protección completa de todas las instalaciones de comunicaciones y procesamiento, durante todo el tiempo.

Arquitectura de seguridad

Arquitectura de seguridad establece los siguientes objetivos y requisitos de seguridad:

- Proteger los datos contra modificaciones no autorizadas.
- Proteger los datos contra pérdida / robo / hurto.
- Proteger los datos contra toda divulgación no autorizada.
- Asegurar la identidad del remitente correcto de los datos.
- Asegurar la identidad del destinatario correcto de los datos.

Servicios de seguridad

Los servicios de seguridad aumentan la seguridad de la información frente a ataques haciendo uso de uno o más mecanismos de seguridad.

- **Confidencialidad:** comprende la protección de los datos transmitidos contra ataques pasivos, es decir, el acceso no autorizado, que incluirá medidas tales como el control de acceso y encriptación.
- **Autenticidad:** está interesada en garantizar que la comunicación sea auténtica, es decir, origen y destino pueden verificar la identidad de la otra parte implicada en la comunicación, con el fin de confirmar que la otra parte es quien dice ser.
- **Integridad:** es la garantía contra ataques activos a través de los cambios o de remociones no autorizadas. Es importante utilizar un esquema que permite la verificación de la integridad de los datos almacenados y su transmisión.
- **No repudio:** comprende el servicio que impide a una fuente o destino negar la transmisión de mensajes, es decir, cuando se envía el mensaje dado, el destino puede demostrar que éste fue enviado realmente por determinado origen y viceversa.
- **Conformidad:** deber de cumplir y hacer cumplir las regulaciones internas y externas impuestas a las actividades de la organización.
- **Control de acceso:** trata de limitar y controlar el acceso lógico / físico a los activos de una organización a través del proceso de identificación, autenticación y autorización, con el fin de proteger los recursos contra el acceso no autorizado.
- **Disponibilidad:** determina que los recursos estén disponibles para el acceso por parte de entidades autorizadas, siempre que lo soliciten, representando la protección contra la pérdida o degradación

Seguridad de la información



La imagen presenta una visión general de la seguridad de la información. Los cambios tecnológicos son una presencia constante en la vida diaria de la organización. Estos cambios pueden hacer que surjan nuevas vulnerabilidades y riesgos, o agravar los ya existentes, por lo cual deben ir acompañados de una evaluación de riesgos dinámica y actualizada, lo que permite el levantamiento de los niveles de riesgo y la forma de tratarlos.

Al mismo tiempo, es necesario conocer las leyes que la organización está obligada a seguir y recopilar los requisitos de seguridad necesarios para cumplir con ella, y a partir de estos requisitos legales, identificar los controles necesarios y los designados por el análisis de riesgos, con el uso de las normas de seguridad. A partir de los controles identificados, es necesario generar políticas, normas y procedimientos para la aplicación de los controles.

Preparando a la organización

Antes de pensar en la gestión de la seguridad de la información en una organización, hay que tener en cuenta:

- ¿Qué hay que proteger? Los activos de la organización requieren protección.
- ¿Contra qué o quién? ¿Cuáles son las amenazas que pueden afectar a la organización y cómo y quién puede explotar estas amenazas?
- ¿Cuál es la importancia de cada recurso? Cada recurso de la información participa en el proceso de negocio de la organización.
- ¿Cuál es el grado de protección deseado?
- ¿Qué requisitos de protección el negocio exige y qué nivel de protección es necesario?
- ¿Cuánto tiempo, recursos financieros y humanos, usted desea gastar para alcanzar los objetivos de seguridad deseados?

- ¿Qué recursos están disponibles para los objetivos de seguridad y qué se puede hacer con los recursos existentes?
- ¿Cuáles son las expectativas de los directivos, clientes y usuarios en materia de seguridad de la información?
- ¿Qué esperan de la seguridad de la información para el negocio de la organización?

Proceso de negocio: conjunto de acciones y actividades que coexisten e interactúan de una manera lógica y coherente para desarrollar un entregable (producto) que cumpla con los requisitos de calidad y las expectativas del cliente, ya sea interno o externo.

Requisitos de seguridad

Hay tres fuentes principales a tener en cuenta al establecer los requisitos de seguridad de la información de una organización:

- **Evaluación/análisis de riesgos:** considera los objetivos y estrategias de negocio de la organización, lo que resulta en la identificación de las vulnerabilidades y las amenazas a los activos. En este contexto, se tiene en cuenta la probabilidad de ocurrencia de las amenazas y el impacto en el negocio.
- **Legislación vigente:** estatutos, reglamentos y las cláusulas contractuales que deben cumplirse para la organización, sus socios, subcontratistas y proveedores.
- **Conjunto de principios:** los objetivos y requisitos de negocios para el procesamiento de datos que la organización debe definir para dar soporte a sus operaciones.

Análisis/evaluación de riesgos

En el análisis/evaluación de riesgo, los gastos en los controles deben ser equilibrados en función del impacto que causará posibles fallas de seguridad en los negocios.

Estos resultados ayudarán a determinar y direccionar las acciones gerenciales y las prioridades para la gestión del riesgo de seguridad de la información.

Selección de controles

Los controles son medidas o conjunto de medidas adoptadas para hacer frente a las vulnerabilidades y reducir el riesgo de incidentes de seguridad de la información.

Los controles de seguridad de la información

Desde el punto de vista legal, existen controles considerados fundamentales y dependen de la legislación vigente, es decir:

- Protección de datos y privacidad de la información personal;
- Protección de los registros de la organización;
- Derechos de propiedad intelectual.

Los controles considerados buenas prácticas para la seguridad de la información son:

- Documento de la política de seguridad de la información;
- Asignación de responsabilidades para la seguridad de la información;
- Sensibilización, educación y capacitación en seguridad de la información;
- Procesamiento correcto en las aplicaciones;
- Gestión de las vulnerabilidades técnicas;
- Gestión de la continuidad del negocio;
- Gestión de incidentes de seguridad de la información.

Elementos relevantes para la seguridad de la información

- Política de seguridad de la información.
- Seguridad organizacional.
- Gestión de activos.
- Seguridad de recursos humanos.
- La seguridad física y del ambiente.
- Gestión de las operaciones y comunicaciones.
- Control de acceso.
- Gestión de incidentes de seguridad de la información.
- Gestión de la continuidad del negocio.

Actividades relacionadas

Actividades adicionales consideradas en el ámbito de la gestión de seguridad de la información:

- Gestión de la seguridad de los sistemas
- Gestión de los servicios de seguridad
- Gestión de los mecanismos de seguridad disponibles para cumplir los requisitos de seguridad de la organización
- Gestión de la auditoría de seguridad, revisión y verificación de registros y eventos de seguridad

Factores críticos para el éxito de la seguridad de la información

- La política de seguridad de la información, los objetivos y las prácticas deben reflejar los objetivos de negocio de la organización.
- El enfoque y la estructura que han sido adoptados para la ejecución, el mantenimiento, el seguimiento y la mejora de la seguridad de la información deben ser compatibles con la cultura de la organización
- Todos los niveles gerenciales de la organización deben estar comprometidos y apoyar la seguridad de la información.
- Los requisitos de seguridad de la información, el análisis, la evaluación y la gestión del riesgo deben ser bien entendidos.
- La seguridad de la información debe darse a conocer, de manera eficiente, a todas las entidades de la organización.
- Distribución y comunicación de directrices, políticas y normas para todas las partes involucradas.
- Suministro de recursos financieros para la gestión de seguridad de la información.
- Suministro de sensibilización, entrenamiento y educación adecuadas.
- Establecimiento de un proceso eficiente para la gestión de incidentes de seguridad.
- Implementación de un sistema de medición de la gestión de seguridad de la información.
- Todos los elementos de la política de seguridad deben ser distribuidos y comunicados a las entidades de la organización.
- Los recursos financieros se deben proporcionar para la gestión de seguridad de la información.
- Medios de sensibilización, formación y educación adecuada deben ser provistos.
- Se debe establecer un procedimiento eficaz para la gestión de incidentes de seguridad de la información.
- Se debe implementar un mecanismo para medir y evaluar la eficacia de la gestión de seguridad de la información, con las sugerencias de mejora posteriores.

Capítulo 2 - Código de buenas prácticas

Estructura de la norma

La norma NTC-ISO/IEC 27002 fue preparada para servir como una guía práctica para el desarrollo y la aplicación de los procedimientos y controles de seguridad de la información en una organización.

Está estructurada para proporcionar un código de buenas prácticas para la gestión de la seguridad, la norma está organizada en capítulos de 0 a 15. Los capítulos 0-4 son considerados como la sección introductoria.

Desde el capítulo 5, la norma llama a cada capítulo como sección. Por lo tanto, hay once secciones específicas que ofrecen los códigos de práctica de la gestión de la seguridad.

Para cada sección, existe al menos una categoría importante de la seguridad. Las once secciones forman un total de 39 categorías principales de seguridad.

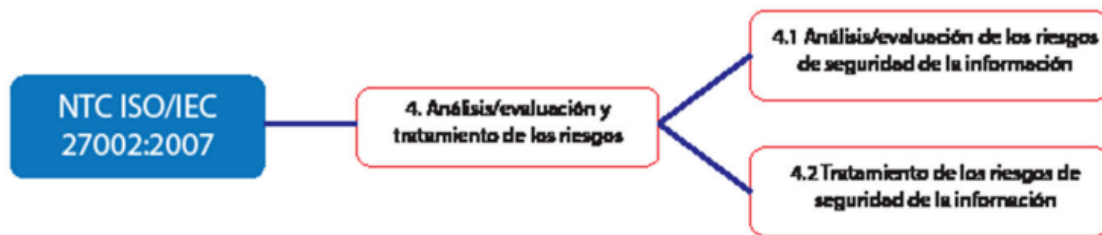
Los controles identificados por números (xx.xx.xx) son estructurados a través de:

- **Control:** descripción y definición de control;
- **Directrices para la implementación:** información auxiliar en la implementación del control;
- **Información adicional:** informaciones complementarias



Sección 4: análisis/evaluación y tratamiento de los riesgos

Presenta objetivamente la importancia del análisis de riesgos para la organización, y las indicaciones generales de la forma en que debe hacerse.



Sección 5: política de seguridad

El objetivo de la categoría de control es proporcionar orientación y apoyo de gestión para la seguridad de la información, mediante el establecimiento de una política clara y objetiva, alineada con los objetivos de negocio de la organización. La sección 5 muestra la forma en que debe ser generado y actualizado el documento de la política.



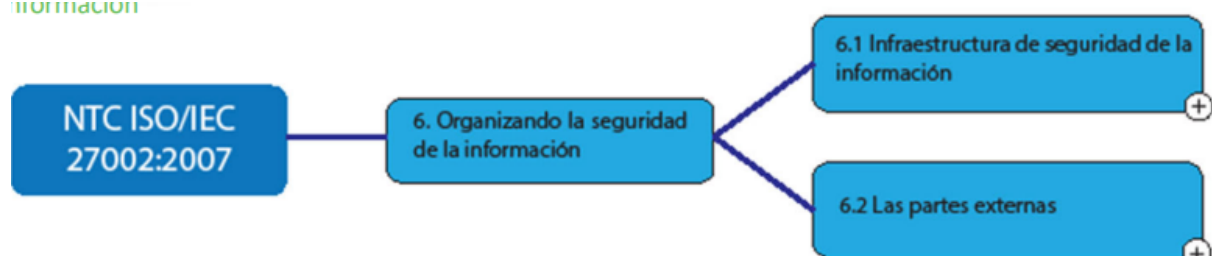
Esta sección se compone de una categoría principal de seguridad (5.1: política de seguridad de la información) y dos controles (5.1.1 y 5.1.2).

El control 5.1.1 muestra lo que conviene que el documento de política contenga y la importancia de que sea comunicado a todos.

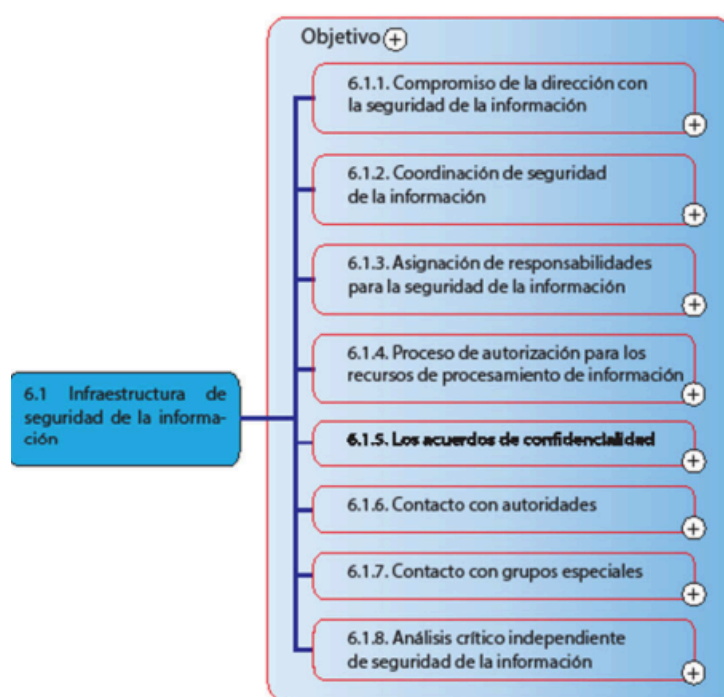
El control de 5.1.2 presenta como corresponde que se realice el análisis crítico por parte de la dirección de la organización.

Sección 6: organizando la seguridad de la información

Su objetivo presentar controles para gestionar la seguridad de la información dentro de la organización y también los controles para mantener la seguridad de los recursos de procesamiento de la información, cuando están disponibles para las partes externas.



Encontraremos los controles que deben aplicarse a la estructura funcional de la seguridad de la información



La categoría 6.1 cuenta con ocho controles que tratan de la estructura de la seguridad, sus procesos de autorización, confidencialidad, y los contactos con otros grupos.

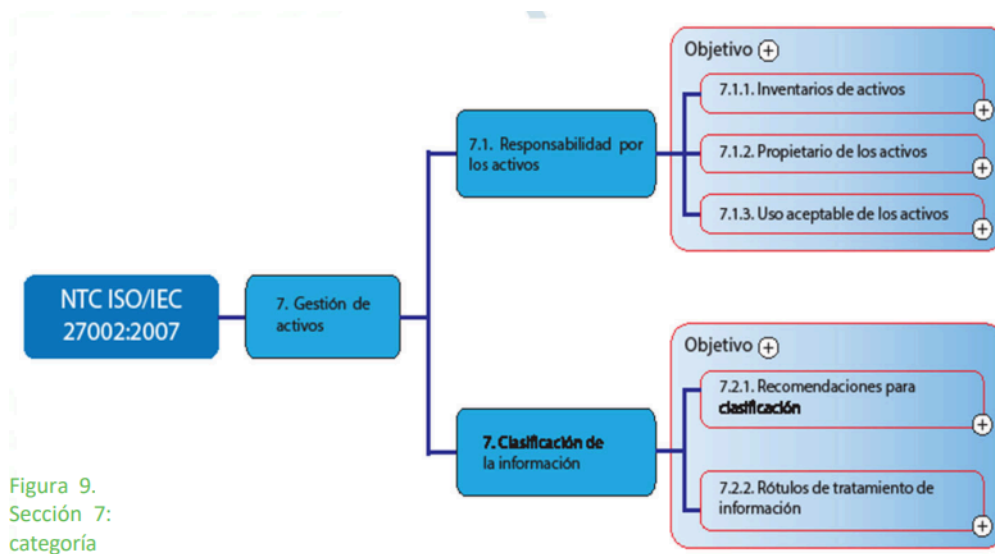


La categoría 6.2 se refiere a los controles necesarios para la relación entre la organización y las partes externas que, en algún momento y por alguna razón del negocio, necesitan tener acceso a los recursos informáticos de la organización.

Sección 7: gestión de activos

Se presentan dos categorías principales de seguridad de la información:

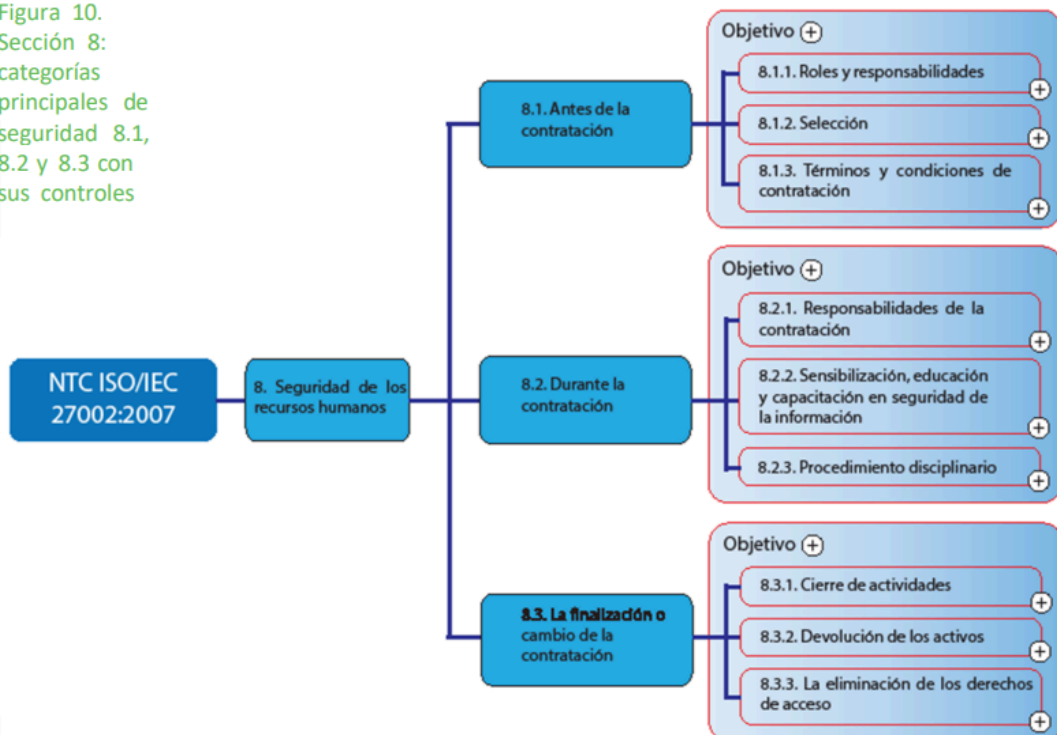
- 7.1 (Responsabilidad de los activos): representa los controles que se aplican a la protección de los activos de la organización. Tiene como objetivo alcanzar y mantener la protección adecuada de los activos de la organización.
- 7.2 (Clasificación de la información): controles para la clasificación de la información, dándoles un nivel de seguridad adecuado.



Sección 8: seguridad de los recursos humanos

Se ocupa de los controles de seguridad de la información durante el ciclo de vida de la prestación de servicio de profesionales en la organización.

Figura 10.
Sección 8:
categorías
principales de
seguridad 8.1,
8.2 y 8.3 con
sus controles



Sección 9: seguridad física y del entorno

Tiene como objetivo del tratamiento de la seguridad física y del ambiente,

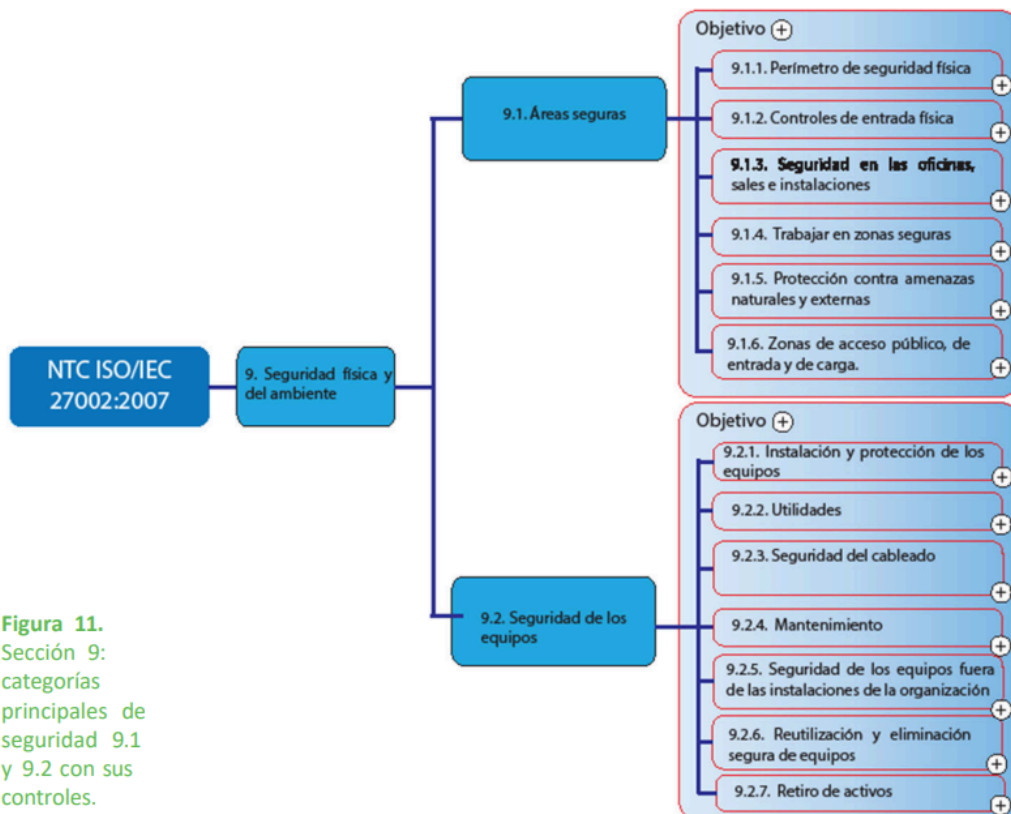


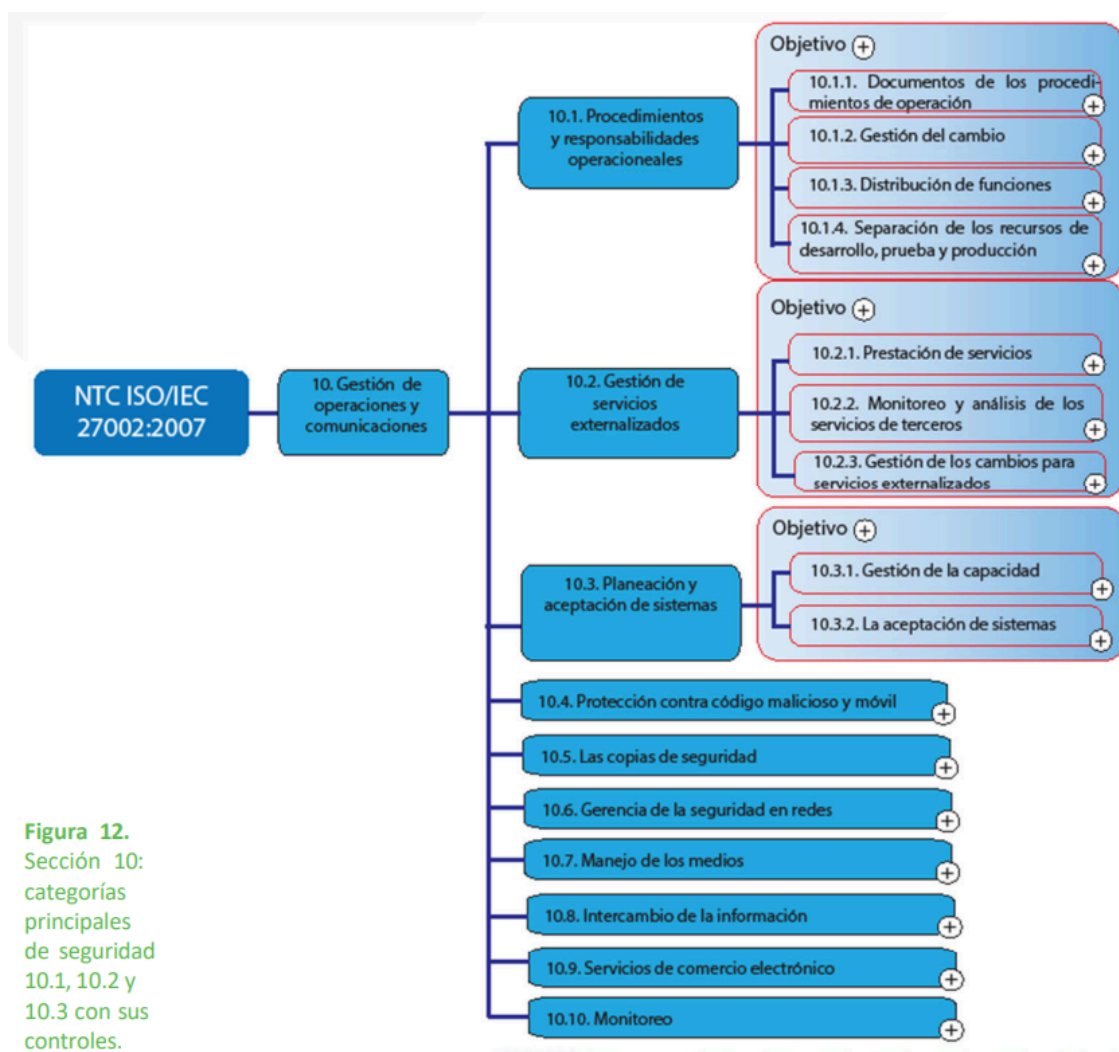
Figura 11.
Sección 9:
categorías
principales de
seguridad 9.1
y 9.2 con sus
controles.

Los controles de seguridad de la categoría 9.1 (áreas seguras) se refieren específicamente a las necesidades de seguridad de acceso físico a las instalaciones.

En la categoría 9.2 (seguridad de equipos) están los controles de seguridad que se refieren a la protección física de los activos y su funcionamiento sin interrupciones.

Sección 10: gestión de operaciones y comunicaciones

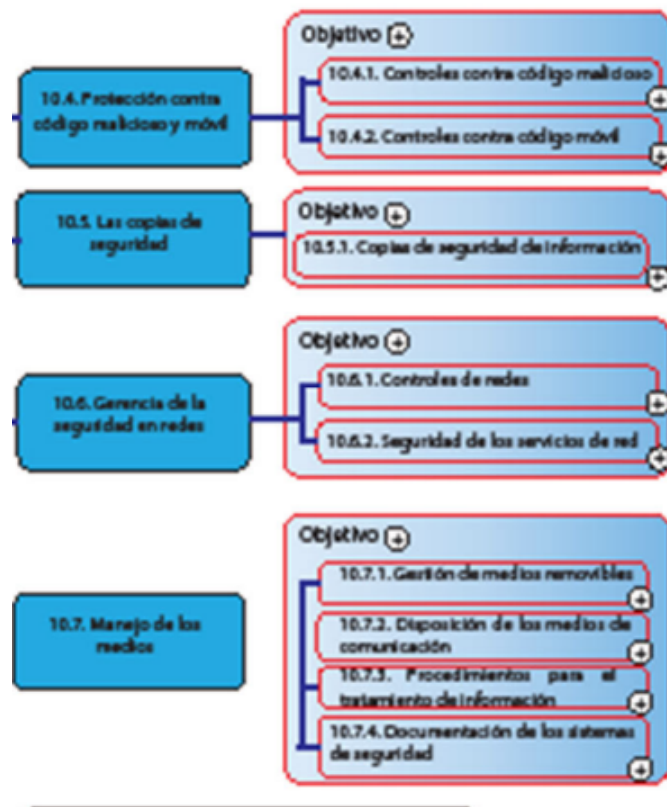
Es la sección más grande de la norma, se ocupa de las operaciones de los servicios tecnológicos de la organización. Esta sección tiene diez categorías principales de seguridad de la información, y cada uno de ellas cuenta con controles que deben ser aplicados en el día a día de las operaciones y las comunicaciones de la organización. Es la sección que muestra los controles de seguridad relacionados con la mayoría de las vulnerabilidades vinculadas a los aspectos operativos cotidianos en el área de las Tecnologías de la Información y las Comunicaciones, TICs.



En la categoría 10.1 (procedimientos y responsabilidades operacionales) se muestran los controles que tienen por objeto garantizar el funcionamiento seguro y correcto de los recursos informáticos.

La categoría 10.2 (gestión de servicios externalizados) tiene como objetivo mantener el nivel adecuado de seguridad y de la entrega de servicios de conformidad con los acuerdos.

En la categoría 10.3 (planeación y aceptación de los sistemas) el objetivo es reducir al mínimo el riesgo de fallas en los sistemas.

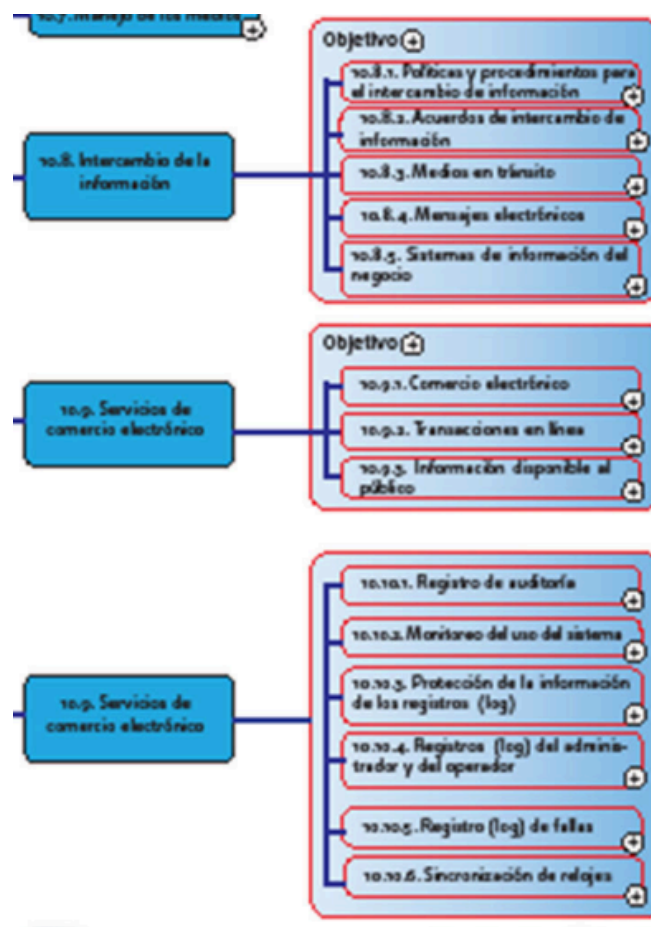


La categoría 10.4 (protección contra códigos maliciosos y móviles) tiene por objeto proteger la integridad del software y la información.

En la categoría 10.5 (copias de seguridad de información), el objetivo es mantener la integridad y disponibilidad de la información.

La categoría 10.6 (gestión de seguridad de la red) tiene por objeto garantizar la protección de la información en las redes y la protección de la infraestructura de soporte.

En la categoría 10.7 (manipulación de medios) se describen los controles que deben ser aplicados para evitar la divulgación no autorizada, modificación, supresión o destrucción.



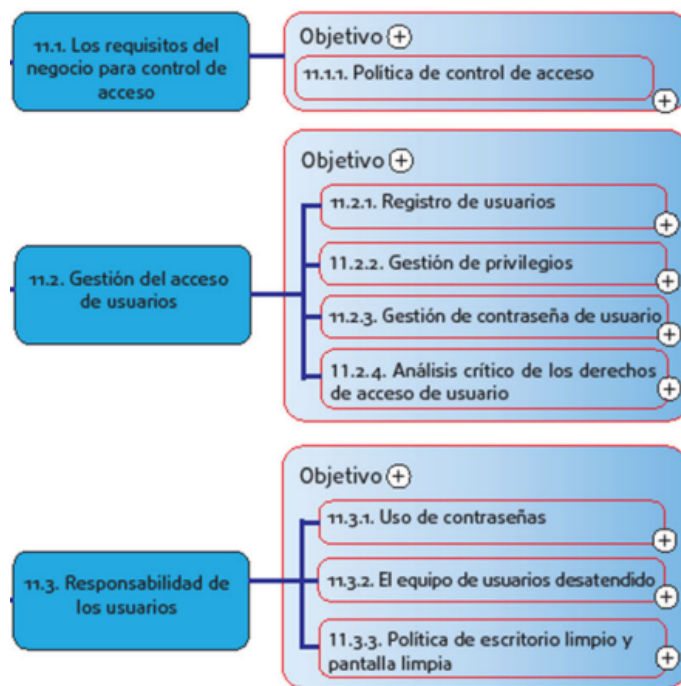
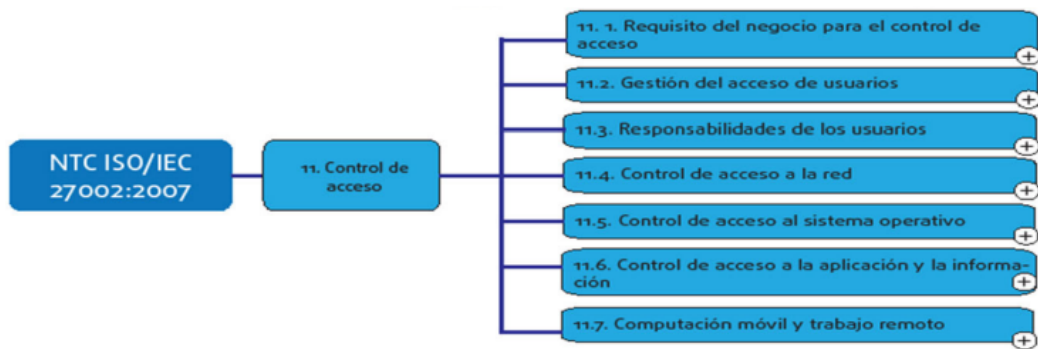
La categoría 10.8 (intercambio de información) tiene como objetivo mantener la seguridad en el intercambio de la información interna y con entidades externas.

En la categoría 10.9 (servicios de comercio electrónico), el objetivo es garantizar la seguridad durante el uso de los servicios de comercio electrónico y su uso seguro.

La categoría 10.10 (monitoreo) tiene como objetivo detectar las actividades no autorizadas de procesamiento de información.

Sección 11: control de acceso

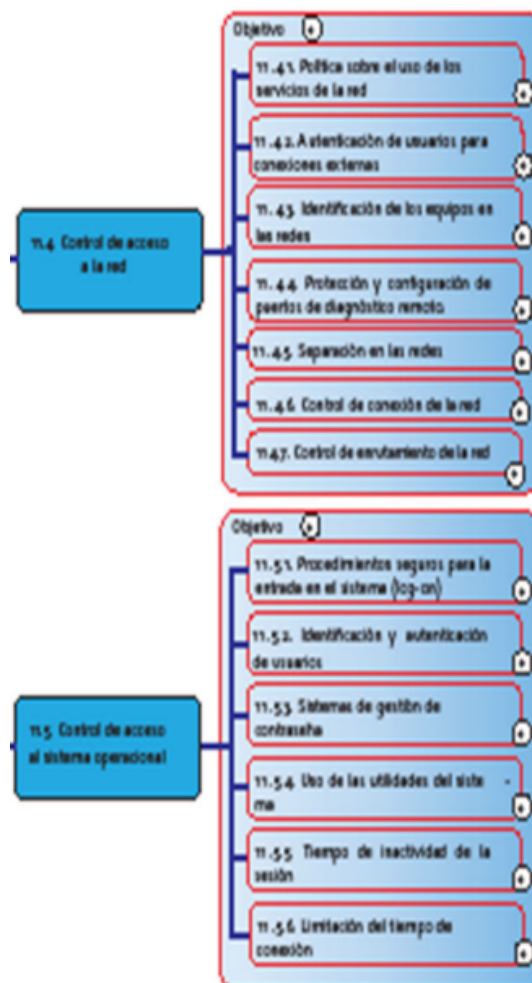
En esta sección se encuentran las categorías que abordan los controles necesarios a los controles de acceso lógico. A diferencia de la sección 9 (seguridad física y del ambiente), en la sección 11 se abordarán aspectos relacionados con los privilegios de acceso, contraseñas, acceso a la red, entre otros.



En la categoría 11.1 (requisitos de negocio para el control de acceso) el objetivo es controlar el acceso a la información.

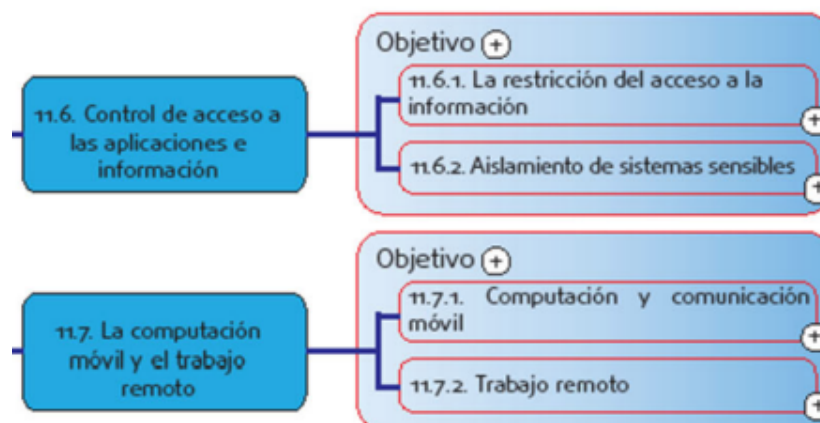
La categoría 11.2 (gestión de acceso de usuario): tiene como objetivo garantizar el acceso a los usuarios autorizados y evitar el acceso no autorizado.

La categoría 11.3 (responsabilidades de los usuarios) tiene por objeto prevenir el acceso no autorizado y evitar la afectación o el robo de los recursos.



La categoría 11.4 (control de acceso a redes) tiene por objeto prevenir el acceso no autorizado a los servicios de red.

La categoría 11.5 (control de acceso al sistema operativo) tiene por objeto prevenir el acceso no autorizado a los sistemas operativos.

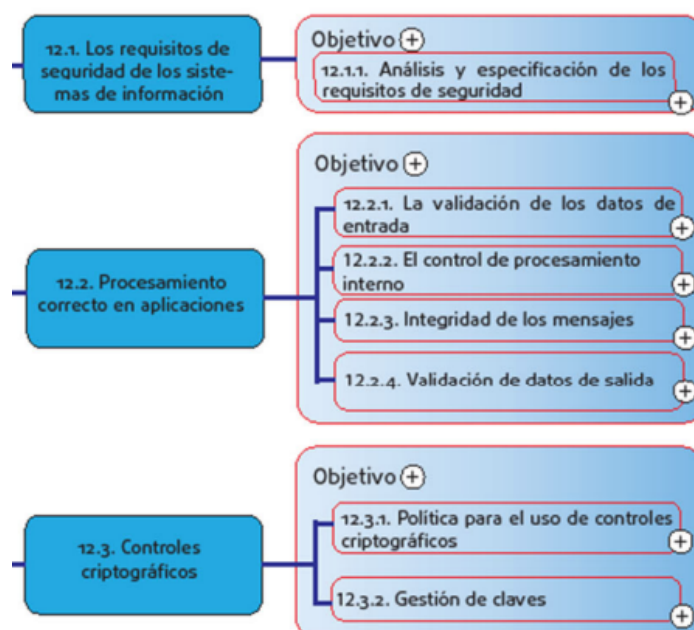
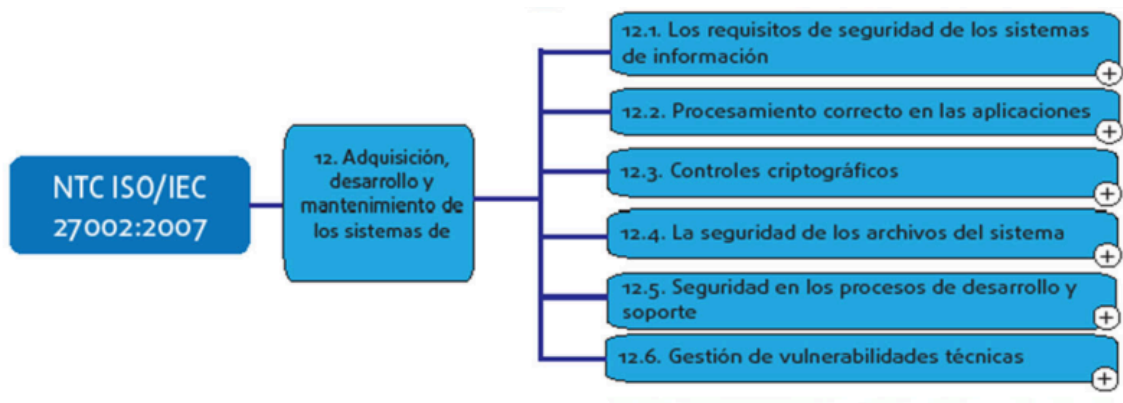


En la categoría 11.6 (control de acceso a las aplicaciones y a la información), el objetivo es prevenir el acceso no autorizado a la información contenida en los sistemas de aplicación.

La categoría 11.7 (computación móvil y trabajo remoto) tiene como objetivo garantizar la seguridad de la información cuando se utilizan la computación móvil y el trabajo remoto.

Sección 12: adquisición, desarrollo y mantenimiento de sistemas de información.

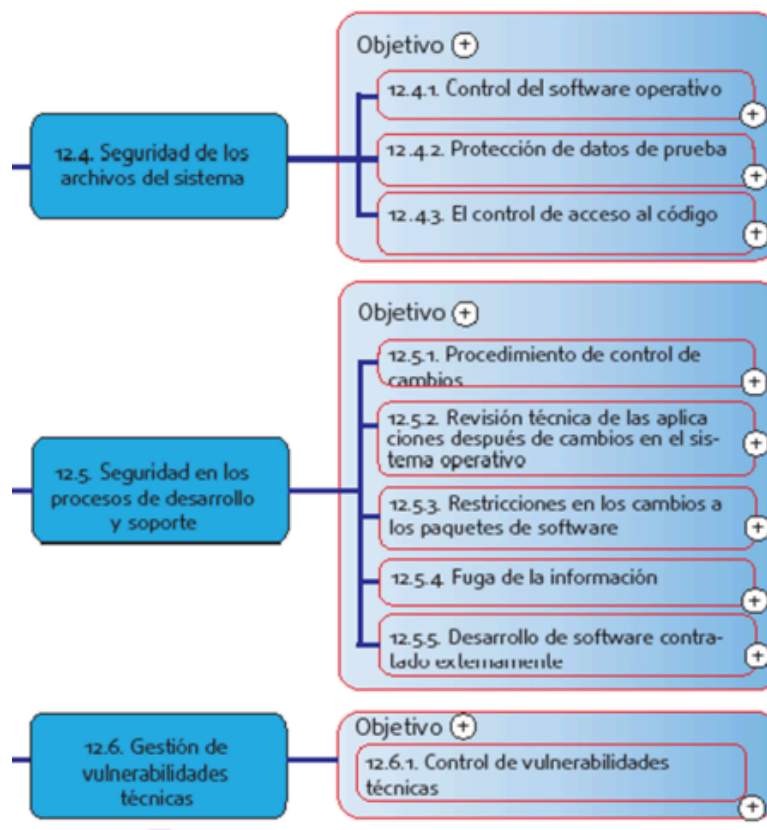
El objetivo de esta sección es desarrollar la seguridad de la información en las aplicaciones de la organización.



La categoría 12.1 (requisitos de seguridad de sistemas de información) tiene por objeto garantizar que la seguridad es una parte integrante de los sistemas de información.

En la categoría 12.2 (procesamiento correcto en las aplicaciones) el objetivo es prevenir la ocurrencia de errores, pérdida, modificación no autorizada o mal uso de la información en las aplicaciones.

La categoría 12.3 (controles criptográficos) tiene por objeto proteger la confidencialidad, autenticidad o integridad de la información por medios criptográficos.



La categoría 12.4 (seguridad de los archivos del sistema) tiene por objeto garantizar la seguridad de los archivos del sistema.

La categoría 12.5 (seguridad en los procesos de desarrollo y soporte) tiene como objetivo mantener la seguridad de los sistemas de información y aplicaciones.

En la categoría 12.6 (gestión de las vulnerabilidades técnicas) el objetivo es reducir los riesgos derivados de la explotación de las vulnerabilidades técnicas conocidas.

Sección 13: gestión de incidentes de seguridad de la información.

Se refiere al reporte de eventos de seguridad, las responsabilidades y el proceso de recolección de evidencia

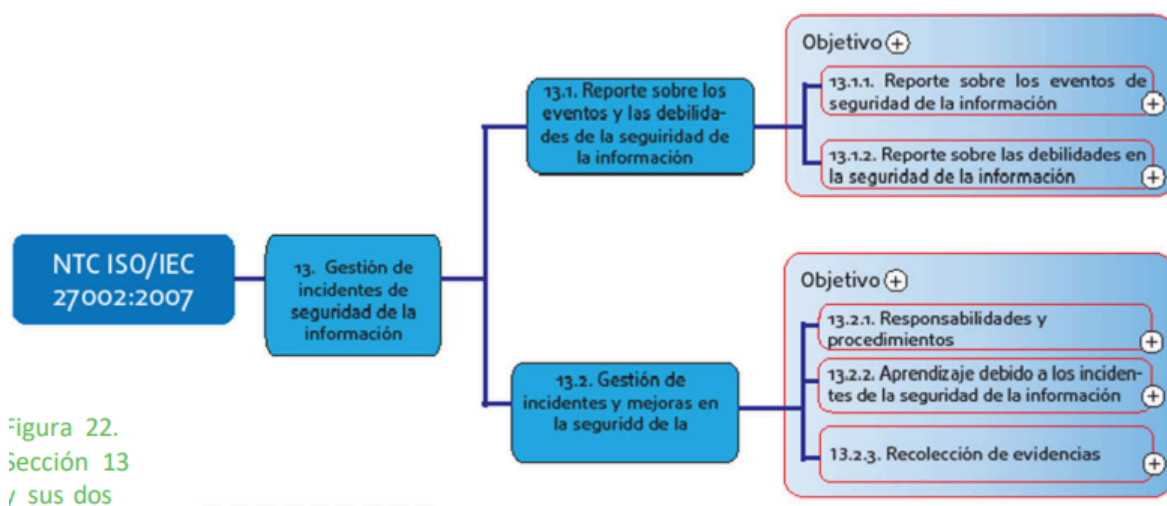


Figura 22.
Sección 13
/ sus dos

La categoría 13.1 (reportes sobre los eventos y las debilidades de la seguridad de la información) tiene como objetivo asegurar que los eventos y las debilidades de la seguridad sean comunicados, permitiendo tomar medidas correctivas en tiempo real.

La categoría 13.2 (gestión de incidentes y mejoras en la seguridad de la información) tiene por objeto garantizar que un enfoque coherente y eficaz sea aplicado a la gestión de incidentes de seguridad de la información.

Sección 14: gestión de la continuidad del negocio

Se encarga de todos los aspectos de la continuidad en el caso de un desastre.

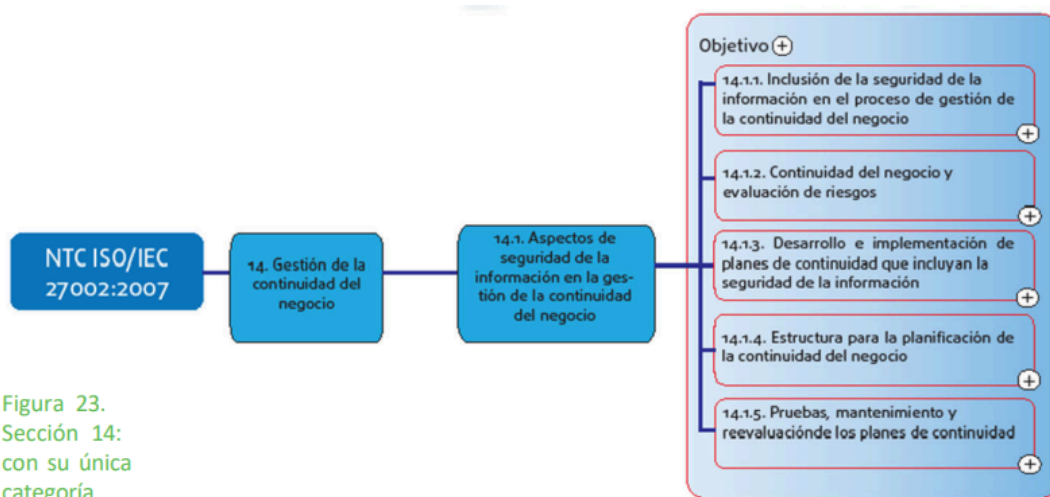


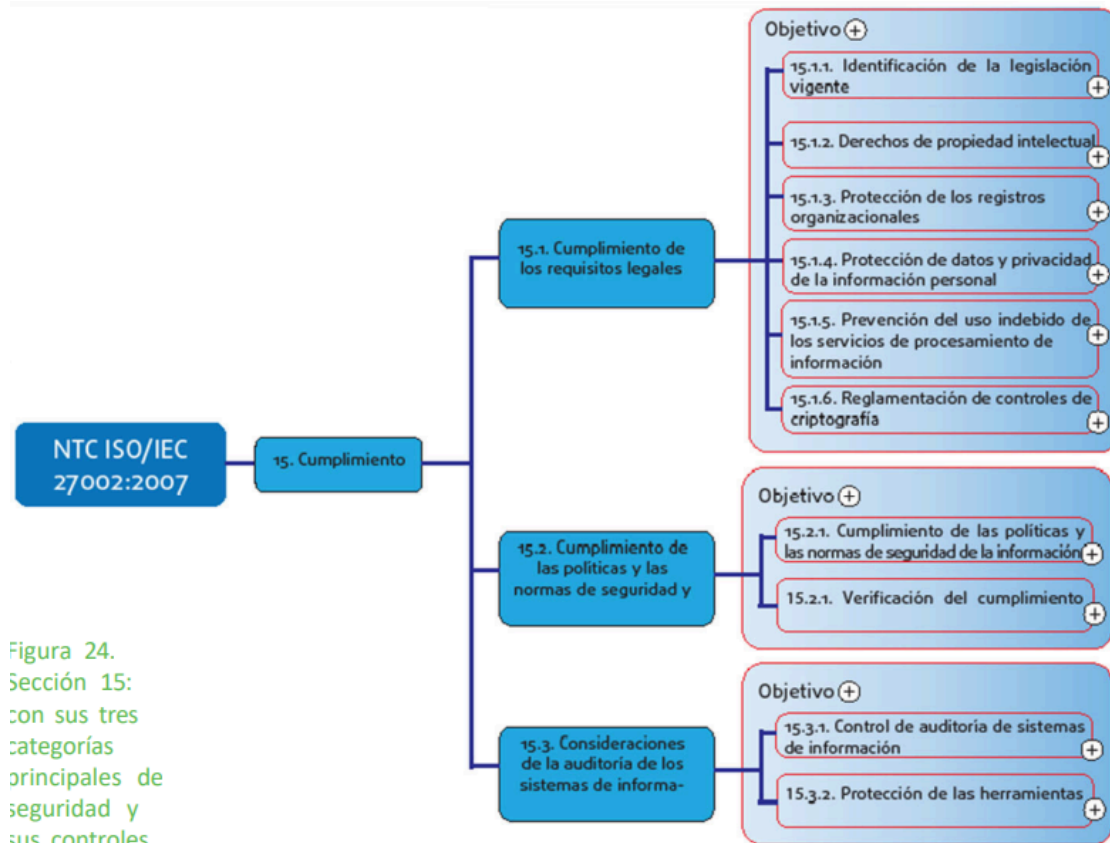
Figura 23.
Sección 14:
con su única
categoría

La categoría 14.1 (aspectos de seguridad de la información en la gestión de la continuidad del negocio) tiene como objetivo no permitir la interrupción de las actividades del negocio y proteger los procesos críticos contra los efectos de fallas o

desastres significativos, y asegurar su reactivación de manera oportuna, si es el caso.

Sección 15: cumplimiento

Establece que los requisitos de seguridad de la información estén de acuerdo con cualquier Ley (legalidad), como reglamentos, estatutos u obligaciones contractuales.



La categoría 15.1 (cumplimiento de los requisitos legales) tiene como objetivo prevenir la violación de cualquier Ley penal o civil, estatutos, reglamentaciones u obligaciones contractuales y cualquier otro requisito de seguridad de la información.

La categoría 15.2 (cumplimiento de las normas y políticas para la seguridad de la información y cumplimiento técnico) tiene por objeto garantizar la conformidad de los sistemas con las políticas y normas organizacionales de seguridad de la información.

En la categoría 15.3 (consideraciones de la auditoría de los sistemas de información), el objetivo es maximizar la eficacia y minimizar la interferencia en el proceso de auditoría de los sistemas de información.

Capítulo 3 - Sistema de gestión de seguridad de la información

Visión general y alcance

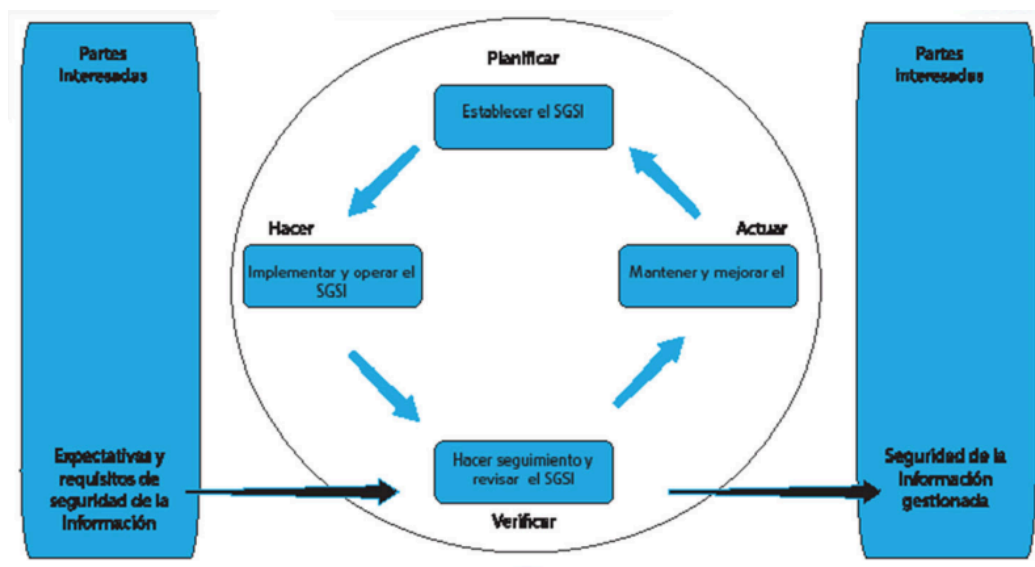
El modelo del SGSI integra la estrategia de la organización y está influenciada por factores tales como:

- Necesidades y objetivos.
- Requisitos de seguridad.
- Procesos.
- Estructura organizacional.

Se espera que la implementación de un SGSI sea proporcional de acuerdo con las necesidades de la organización.

Modelo PHVA

La norma ISO 27001 adopta el modelo conocido como PHVA, que se aplica para estructurar todos los procesos del SGSI.



El modelo PHVA comprende un conjunto de acciones en la secuencia establecida por las letras que componen las siglas:

- **Planear** (establecer el SGSI): establecer las políticas, objetivos, procesos y procedimientos del SGSI, relevantes para la gestión del riesgo y la mejora de la seguridad de información, para conseguir resultados de acuerdo con las políticas y objetivos generales de una organización.

- **Hacer** (implementar y operar el SGSI): implementar y operar las políticas, controles, procesos y procedimientos del SGSI.
- **Verificar** (comprobar: monitorear y analizar críticamente el SGSI): evaluar y, si es el caso, medir el desempeño de un proceso con base en la política, los objetivos y la experiencia práctica del SGSI y presentar los resultados para la revisión de la dirección.
- **Actuar** (mantener y mejorar el SGSI): llevar a cabo las acciones correctivas y preventivas, basadas en los resultados de la auditoría interna del SGSI y el análisis crítico realizado por la dirección u otra información pertinente, para lograr la mejora continua del SGSI.

Sistema de Gestión de la Seguridad de la Información, SGSI

El SGSI es un proceso estructurado de tratamiento de seguridad de la información en los diversos sectores.

Estableciendo y gerenciando el SGSI

Se presenta cada etapa en la gestión de un SGSI:

- Establecer el SGSI.
- Implementar y operar el SGSI.
- Monitorear y analizar críticamente el SGSI.
- Mantener y mejorar el SGSI.

Establecer el SGSI

Los siguientes requisitos se deben cumplir dentro de cualquier organización, al iniciar un proceso de establecimiento de un SGSI:

- **Definir el alcance:** debe considerar las características del negocio, la organización, la ubicación, los activos y la tecnología;
- **Definir la política de seguridad:** debe estar alineada con el contexto de la gestión del riesgo en la organización, y establecer criterios para la evaluación y ser aprobado por la dirección;
- **Definir la estrategia de evaluación de riesgos:** determinar la metodología y desarrollar criterios para la aceptación;
- **Hacer la identificación, análisis y evaluación de riesgos:** identificar los activos, vulnerabilidades y amenazas. Evaluar posibles daños, estimar la probabilidad y calcular el riesgo, determinando si éste es aceptable o requiere tratamiento;
- **Identificar y evaluar las opciones para el tratamiento de los riesgos:** implementar controles, aceptar, evitar, transferir el riesgo;

- **Seleccionar los controles y los objetivos para el tratamiento del riesgo:** seleccione los controles de la norma que han de aplicarse;
- **Obtener aprobación para los riesgos residuales;**
- **Obtener el consentimiento para la implementación del SGSI;**
- **Preparar la declaración de aplicabilidad:** debe relacionar los objetivos de control y los controles seleccionados, justificando obligatoriamente aquellos no seleccionados.

Implementación y operación del SGSI

Se debe analizar, para el ambiente de la organización, la forma de cumplir los requisitos de implementación y operación:

- **Formular e implementar el tratamiento del riesgo**
- **Implementar los controles seleccionados**
- **Definir parámetros para medir la eficacia de los controles**
- **Implementar un programa de entrenamiento:** poseer y poner en práctica un programa de capacitación eficaz
- **Gestionar las operaciones del SGSI:** saber cómo está funcionando el SGSI y buscar áreas de mejora
- **Gestionar los recursos para el SGSI:** comprobar si los recursos son suficientes
- **Implementar controles capaces de detectar y responder a los incidentes de seguridad**

Monitoreo y análisis crítico del SGSI

- **Ejecutar los procedimientos de monitoreo y análisis crítico:** detectar los errores en el procesamiento, identificar inmediatamente las fallas, brechas de seguridad e incidentes, y controlar si se llevan a cabo las actividades delegadas como fue especificado, en caso de una falla de seguridad;
- **Llevar a cabo revisiones periódicas de la eficacia del SGSI;**
- **Revisar el riesgo:** considerar los cambios relacionados con la organización, la tecnología, los objetivos y los procesos de negocio, las amenazas identificadas, eventos externos, tales como contratos, la legislación y el contexto social;
- **Actualizar el plan de seguridad;**
- **Mantenga registro de las acciones y eventos que han impactado sobre la eficacia o el rendimiento del SGSI.**

Mantenimiento y mejora del SGSI

- **Implementar las mejoras identificadas**
- **Ejecutar las acciones preventivas y correctivas**

- **Comunicar las acciones y mejoras**
- **Asegurar que las mejoras alcancen sus objetivos:** crear mecanismos para comprobar que se están cumpliendo los objetivos.

Requisitos generales de la documentación

La documentación dentro de un SGSI es un importante factor de éxito, dado que demuestra la relación de los resultados esperados con los controles implementados. La documentación será a menudo la evidencia necesaria para averiguar que un SGSI está implementado de manera correcta y eficiente, permitiendo que las acciones puedan ser trazables y reproducibles.

Los documentos que se enumeran a continuación son los requisitos generales obligatorios y la base documental requerida para la auditoría de un SGSI:

1. Declaración de la política de seguridad y los objetivos del SGSI;
2. Alcance;
3. Procedimientos y controles;
4. Descripción de la metodología de análisis / evaluación de riesgos;
5. Informe de análisis / evaluación de riesgos;
6. Plan de tratamiento de riesgos;
7. Procedimientos necesarios para garantizar la eficacia, la operación y los controles;
8. Descripción de la medición de la eficacia de los controles;
9. Registros requeridos.

Control de documentos

- Aprobar la documentación.
- Revisar, actualizar y rechazar cuando sea necesario.
- Garantizar que los cambios y el estado de actualización estén identificados.
- Garantizar que los documentos pertinentes están disponibles en los puntos de uso en la versión más reciente.
- Garantizar que los documentos permanecen legibles y fácilmente identificables.
- Garantizar que los documentos de origen externo sean identificados.
- Garantizar que la distribución sea controlada.
- Aplicar la debida identificación en caso de que se retengan por cualquier razón.

Control de registros

Los registros deben establecerse y mantenerse para demostrar:

- La evidencia de la conformidad con los requisitos y la efectividad de la operación del SGSI.
- Conformidad con las obligaciones contractuales.

Los registros deben ser solicitados durante las entrevistas de auditoría para comprobar la ejecución de los controles.

Responsabilidad de la dirección

El compromiso de la dirección de la organización es fundamental para la implementación y mantenimiento del SGSI. Es a través de este compromiso que los otros miembros de la organización comprenden la importancia y la necesidad de consolidar un SGSI.

La organización debe determinar y proporcionar los recursos necesarios para el establecimiento y el mantenimiento del SGSI.

Auditorías internas del SGSI

La organización debe realizar auditorías internas a intervalos planificados para determinar objetivos, controles, procesos y procedimientos del SGSI.

Una auditoría debe planificarse teniendo en cuenta el estado y la importancia de los procesos y las áreas a auditar, así como los resultados de las auditorías previas. Se deben definir los criterios de auditoría, su alcance, frecuencia y métodos.

Análisis crítico del SGSI

La dirección debe analizar críticamente el SGSI a intervalos planificados para asegurarse de su conveniencia, adecuación y eficacia continua. Esta revisión debe incluir oportunidades de mejora y las necesidades de cambio del SGSI, incluyendo la política y objetivos de seguridad. Los resultados de esta revisión deben ser claramente documentados y los registros deben mantenerse.

Datos de entrada

Datos de entrada del análisis crítico:

- Los resultados de las auditorías internas.
- Retroalimentación de las partes interesadas.
- Técnicas, productos o procedimientos que se pueden utilizar en la organización para mejorar el SGSI.
- Estado de las acciones correctivas y preventivas.
- Vulnerabilidades o amenazas no contempladas.
- Resultado de indicadores del SGSI.

- Acompañamiento de las acciones de las revisiones gestionadas.
- Recomendaciones para la mejora.
- Cualquier cambio que pueda afectar el SGSI.

Datos de salida

Los datos de salida de un proceso de análisis crítico son:

- Mejora de la eficacia del SGSI.
- Actualización de análisis / evaluación y plan de tratamiento de riesgos.
- Modificación de los procedimientos y controles que afectan a la seguridad de la información.
- La necesidad de recursos;
- Mejoras en el control de la eficacia del SGSI.

Mejora del SGSI

La organización debe mejorar continuamente la eficacia del SGSI.

- **Acciones correctivas:** la organización debe tomar acciones correctivas para eliminar las causas de las no conformidades con los requisitos del SGSI para evitar su repetición.
- **Acciones preventivas:** la organización debe determinar acciones para eliminar las causas de no conformidades potenciales con los requisitos del SGSI, para prevenir su ocurrencia.

Controles detallados

La gestión de la seguridad de la información fomenta la adopción de políticas, procedimientos, directrices y otros elementos pertinentes, cuyo alcance debe comprender la gestión del riesgo sobre la base de costo/ beneficio para la organización, entre ellos se encuentran:

- Política de seguridad de la información.
- Seguridad organizacional.
- Gestión de activos.
- Seguridad de los recursos humanos.
- Seguridad física y del ambiente.
- Gestión de las operaciones y las comunicaciones.
- Control de acceso.
- Adquisición, desarrollo y mantenimiento de SI.
- Gestión de incidentes de seguridad.
- Gestión de la continuidad del negocio

Capítulo 4 - Política de seguridad de la información

Definición

La política de seguridad de la información es un conjunto de lineamientos basados en unas normas y procedimientos que determinan las reglas y procedimientos a seguir para garantizar la seguridad de la información, de acuerdo con el tipo de negocio y los requisitos legales, contractuales, regulatorios y normativos aplicables a todo el alcance de la organización. Ella establecerá las directrices, límites, responsabilidades y objetivos de los controles que se deben implementar e implantar para garantizar los requisitos de protección de seguridad de la información en la organización.

Por lo tanto, la política de seguridad debe estar claramente definida, publicada, actualizada y apoyada por los dirigentes de la organización.

Diagrama

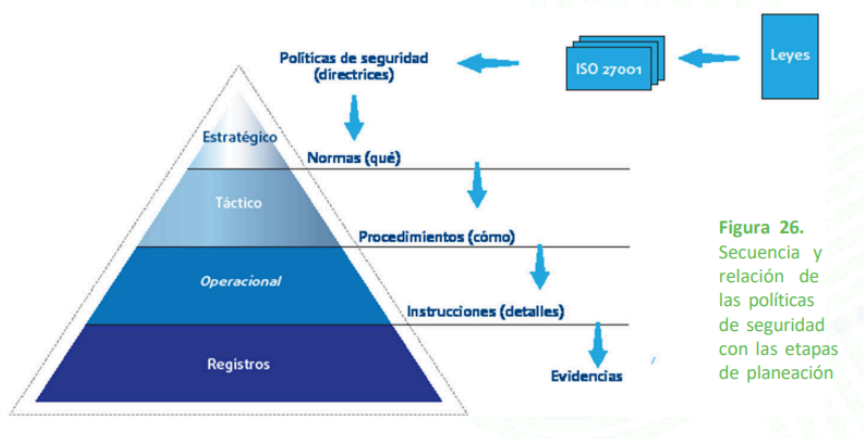


Figura 26.
Secuencia y
relación de
las políticas
de seguridad
con las etapas
de planeación

Políticas	Directrices que se deben seguir. Responde al "por qué" realizar la seguridad de la información, definiendo directrices genéricas de lo que debe hacer la organización para lograr la seguridad de la información.
Normas	Reglas básicas de cómo debe ser implementado el control o conjunto de controles, que se definieron en las políticas. Responden "qué" hacer para alcanzar las directrices definidas en la política de seguridad.
Procedimientos	Actividades detalladas sobre cómo deben ser implementados los controles o conjunto de controles. Responde "cómo" hacer cada elemento definido en las normas específicas y sus políticas.
Instrucciones	Descripción de una operación o conjunto de operaciones para la ejecución de la implementación de los controles de seguridad de la información.
Evidencias	Mecanismos adoptados para permitir la recolección y verificación de la aplicación de los controles de seguridad de la información, su eficacia y eficiencia. Permite la trazabilidad y su uso en auditorías.

Arquitectura de políticas de seguridad



Estas pueden ser vistas como las políticas de seguridad necesarias, pero que deben ser adecuadas a las necesidades de cada organización.

Alcance

En una organización, la política de seguridad debe:

- Establecer los principios a seguir con el fin de proteger, controlar y monitorear sus recursos y su información;
- En particular, la política de seguridad de la información puede ser integrada a otras políticas y planes existentes en la organización, como las políticas de contingencia y el plan estratégico de negocios.
- Al definir el alcance de la política, detallar los límites de su aplicación, citando los ambientes físicos, lógicos y organizacionales que son aplicables y tipos de usuarios, entre otros.

Preguntas importantes

Se debe tener en cuenta las respuestas a las siguientes preguntas:

- ¿Qué desea proteger? Activos de la organización que requieren protección.
- ¿Contra qué o quién? ¿Cuáles son las amenazas que pueden afectar a la organización y cómo y por quién estas amenazas pueden ser explotados?
- ¿Cuáles son las amenazas más probables? Identificar las amenazas que tienen más posibilidades de ocurrir.
- ¿Cuál es la relevancia de cada recurso a ser protegido? Importancia del recurso dentro del proceso de negocio
- ¿Cuál es el grado de protección requerido? Requisitos de protección que el negocio requiere. ¿Qué nivel de protección es necesario?

- ¿Cuánto tiempo, recursos financieros y humanos están a disposición?
¿Cuáles recursos están disponibles para fines de seguridad? ¿Qué se puede hacer con los recursos existentes?
- ¿Cuáles son las expectativas de los usuarios y clientes? ¿Qué espera usted de la seguridad de la información para el negocio de la organización, servicios y productos?

Etapas

La política de seguridad debe implantarse de acuerdo con un proceso formal, pero flexible, para permitir cambios de acuerdo a las necesidades. Una propuesta típica para la implementación de una política de seguridad de la información comprende:

- Identificar las leyes aplicables a la organización
- Identificar los recursos críticos
- Clasificar la información de la organización, no sólo observando el área de informática, sino todos los sectores y su información;
- Analizar las necesidades de seguridad, con el objetivo de identificar las posibles amenazas, los riesgos y los impactos en la organización;
- Preparar la propuesta de la política de seguridad;
- Discutir abiertamente con todos los involucrados el contenido de la propuesta presentada;
- Aprobar la política de seguridad;
- Implementar la política de seguridad;
- Hacer mantenimiento, regularmente, de la política de seguridad, buscando identificar las mejoras necesarias y hacer las revisiones necesarias.

Documentación

La política de seguridad de una organización debe ser documentada, y el documento generado debe ser aprobado por sus dirigentes para que pueda ser publicado y difundido a todos los involucrados.

La política de seguridad debe contener los siguientes elementos:

- La definición de seguridad de la información, sus objetivos, el alcance y relevancia para la organización;
- Declaración del compromiso de los líderes de la política de seguridad de la organización;
- Indicación de los objetivos de control y de los controles, incluyendo el análisis / evaluación y la gestión del riesgo;
- Breve explicación acerca de las políticas, principios, normas y requisitos para garantizar la conformidad con la legislación, reglamentos, contratos y normas de seguridad;

- Definición de las responsabilidades con la gestión de seguridad de la información;
- Las referencias a los documentos que sustentan la política de seguridad.

Aprobación e implementación

La fase de aprobación de la política de seguridad corresponde al resultado positivo obtenido tras el análisis de la propuesta elaborada y presentada a la organización. En particular, ésta exige el apoyo de los líderes de la organización.

En la implementación deben ser considerados todos los aspectos relacionados con la implementación de mecanismos de seguridad apropiados para garantizar que las necesidades de seguridad levantadas previamente son atendidas adecuadamente.

Comunicación de la política y entrenamiento

Se recomienda que la divulgación haga parte de la formación de los empleados nuevos y de la actualización de los antiguos, además de que se realicen periódicamente. Esta política de divulgación debe ser formal y efectiva, indicando todos los detalles de su implementación, cómo debe ser cumplida y las sanciones, en caso de incumplimiento. Recuerde que la mejor medida de prevención es la educación.

Mantenimiento

La política de seguridad de la información adoptada en una organización debe analizarse periódicamente (se recomienda anualmente), con el objetivo de mantener su idoneidad y su eficiencia. También debe ser revisado en caso de cambios significativos en cuanto a los negocios y avances tecnológicos.

A continuación, se debe generar el nuevo documento de la política de seguridad, y este, a su vez, debe ser reconocido y apoyado por los líderes de la organización.

Buenas prácticas

Para obtener mejores resultados se recomiendan las siguientes buenas prácticas, al considerar la política de seguridad de una organización:

- La alta dirección de la organización debe apoyar y creer que las políticas de seguridad de la información van a proteger su información.
- No siempre es posible detectar una violación de la política de seguridad, sin embargo, en situaciones donde hay una posibilidad, es importante identificar la causa en primera instancia. Por otra parte, se recomienda que en la

política de seguridad que establezcan los procedimientos a seguir si se produce una violación, según su gravedad, determinando también las acciones correctivas necesarias y sanciones a los responsables directos del problema.

- Es saludable establecer una estructura organizativa responsable de la seguridad de la información en la organización, con el fin de determinar las personas responsables de la aprobación, revisión y gestión de la implementación de la política de seguridad en la organización.
- Se debe trabajar la seguridad del personal para minimizar o incluso evitar los problemas de seguridad de la información con causa proveniente de errores humanos.

Otras buenas prácticas

El control y la clasificación de los recursos informáticos de la organización son relevantes.

La implementación del control de acceso lógico y físico para establecer los límites de acceso son recomendados, utilizando dispositivos de control de entrada y salida.

La auditoría de seguridad de la información debe ser una actividad periódica de la organización con el fin de verificar si la política de seguridad es eficiente y si hay necesidad de actualizaciones.

Buenas prácticas para escribir el texto de la política

- **Definir el objetivo del documento**
- **Use textos cortos y objetivos**
- **Definir los roles y responsabilidades con respecto a la política de seguridad.**
- **Evitar el uso de términos técnicos o lengua extranjera**
- **Evitar el uso de “no”:** si es necesario, utilice “está prohibido”, “negar”, “está vetado”, entre otros.
- **Evitar el uso de “excepto” o “en principio”**
- **Crear en la política un elemento para las definiciones y los conceptos:** definir en el principio del documento todos los conceptos, definiciones, términos técnicos y acrónimos que se utilizarán en la política.
- **Penalización:** definir las posibles sanciones para aquellos usuarios que no cumplan con la política
- **Crear reglas y recomendaciones factibles de ser implementadas y cumplidas por toda la organización y en todos los niveles jerárquicos.**
- **Tenga cuidado con la estructura gramatical**
- **Solicitar que la oficina jurídica evalúe el documento y certifique su aceptación.**

Capítulo 5 - La gestión del riesgo

Definiciones

Riesgo de seguridad es una combinación de amenazas, vulnerabilidades e impactos. Las amenazas son eventos que aprovechan las vulnerabilidades (debilidades) y pueden causar daños. El impacto es el resultado de una vulnerabilidad al ser explotada por una amenaza.

En cuanto a la gestión del riesgo:

- La gestión del riesgo incluye todas las medidas adoptadas para controlar los riesgos en una organización, incluyendo el análisis/ evaluación, el tratamiento, la aceptación y la comunicación de los riesgos.
- El análisis de riesgos identifica y estima los riesgos, teniendo en cuenta el uso sistemático de la información
- La evaluación del riesgo compara el riesgo estimado en el análisis con los criterios predefinidos con el fin de identificar la importancia de cada riesgo para la organización.
- La aceptación de riesgos incluye la identificación del nivel aceptable de riesgos para una organización en función de sus necesidades específicas de negocio y seguridad.
- El tratamiento del riesgo corresponde a la selección y la aplicación de medidas para modificar un determinado riesgo.
- La comunicación de riesgos involucra iniciativas para mostrar los riesgos a los empleados, directivos y terceros

Cuestiones claves

Se recomienda clasificar los riesgos según los criterios: nivel de importancia, gravedad de las pérdidas y costos involucrados en la prevención o recuperación de desastres.

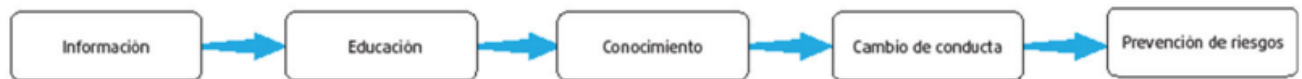
Si el costo para evitar una amenaza es mayor que su daño potencial, es aconsejable tener en cuenta otras medidas.

La gestión del riesgo

La gestión del riesgo debe considerar los siguientes tres niveles de aplicación: tecnologías, procesos y personas. La tecnología garantiza los ajustes técnicos necesarios para el tratamiento adecuado de los riesgos; los procesos de asegurar que las actividades que componen la gestión de los riesgos sean consideradas de forma sistemática, y, por último, las personas, de modo que los empleados y los

gerentes identifiquen sus responsabilidades, conozcan los riesgos y puedan ayudar a su reducción y control.

En cuanto a las medidas de seguridad, se recomienda atención a las siguientes categorías: preventivas, correctivas e ilustrativas.



Análisis y evaluación de riesgos

El análisis/evaluación de riesgos consiste en identificar, cuantificar y calificar los riesgos de seguridad de la información, con base en los objetivos de la organización. Incluye también la priorización de los riesgos, teniendo en cuenta los criterios de riesgo aceptable.

Algunos aspectos de análisis / evaluación de riesgos que deben ser contemplados son:

- Deben ser llevados a cabo de manera sistemática con el fin de identificar los riesgos (análisis) y calificar el riesgo (evaluación)
- Debe utilizar métodos específicos para permitir la comparación entre los resultados obtenidos y su reproducción.
- Debe realizarse periódicamente o cuando los requisitos de seguridad, activos, vulnerabilidades y / o los objetivos de negocio sufren algún cambio.

Analizando los riesgos

El análisis de riesgo debe considerar los daños probables al negocio resultantes de fallas de seguridad; la probabilidad de que las fallas ocurran frente a las vulnerabilidades y amenazas existentes; y las medidas de seguridad implementadas (si es aplicable) para que al final, se recopilen los datos necesarios para la adecuada gestión del riesgo.

Por lo tanto, algunas preguntas deben ser contestadas:

- ¿Qué hay que proteger?
- ¿Cuáles son las vulnerabilidades y amenazas?
- ¿Cómo analizar?

¿Qué hay que proteger?

Se deben considerar todos los activos involucrados en el alcance del SGSI de la organización, especialmente los directamente relacionados con los objetivos del negocio. Se recomienda hacer un inventario cuidadoso de los activos.

Vulnerabilidades y amenazas

Se deben considerar las probabilidades de cada activo de ser vulnerable a las amenazas. Para ello, hay que prestar atención a la información que pueda quedar comprometida y los servicios de seguridad que puedan verse comprometidos.

Ejemplos de amenazas típicas:

- Desastres naturales
- Falta de suministro de energía eléctrica.
- Robo/estafa
- Amenazas programadas.
- Fallas de hardware.
- Fallas de software.
- Errores humanos.

Análisis de los impactos

El impacto es el resultado cuando se produce una amenaza.

Para el análisis de los impactos, se puede considerar una propuesta de clasificación específica de apoyo. Por lo general, los impactos de las amenazas a la organización se analizan desde dos aspectos: a corto y largo plazo, teniendo en cuenta el periodo de tiempo durante el cual un impacto permanece afectando a los negocios.

Se puede utilizar una escala de 0 (impacto irrelevante) a 5 (efectos desastrosos que comprometen la supervivencia de la organización).

Matriz de relaciones

La matriz de relaciones es una forma simplificada de visualizar las amenazas, impactos y las probabilidades.

Amenazas	Impacto	Probabilidad
Errores humanos		
Instalación de hardware y software no autorizado		
Códigos maliciosos		
Errores en los sistemas operativos		
Invasión		
Desastres naturales		

Cálculo del riesgo

Los riesgos se calculan a partir de la relación entre el impacto y probabilidad de ocurrencia, es decir, $\text{riesgo} = \text{impacto} * \text{probabilidad}$

Al realizar la multiplicación, obtenemos un rango de valores para el riesgo del 0 (sin riesgo) a 25 (muy alto riesgo).

La evaluación de riesgos

Al evaluar los riesgos se busca una base que sirve para fines de comparación. El conocimiento previo de los impactos y las probabilidades de riesgo siempre es relevante para una evaluación adecuada y completa.

Hay básicamente dos formas de realizar la evaluación del riesgo:

- **Cualitativo:** evaluación de riesgos a través de la estimación cualitativa es la que utiliza calificadores y atributos descriptivos para evaluar. No se asignan valores financieros. Se considera muy subjetiva. Ejemplo: Alto, Medio, Bajo, Muy Bajo.
- **Cuantitativo:** evaluación de riesgos a través de una estimación cuantitativa es aquella que utiliza valores numéricos financieros para cada uno de los componentes recolectados durante la identificación de los riesgos. Ejemplo: 50% de probabilidad; el impacto: \$ 100.000.000.

El tratamiento de los riesgos de seguridad

Se debe indicar el procedimiento para el tratamiento de los riesgos. Entre las alternativas de tratamiento se destacan:

- Seleccionar y aplicar las medidas de seguridad adecuadas para reducir los riesgos a un nivel aceptable
- Implementar medidas de prevención frente a los riesgos, no permitiendo que las vulnerabilidades sean explotadas para la materialización del riesgo
- Transferir los riesgos a terceros mediante contratos con las compañías de seguros

En cuanto al tratamiento de los riesgos de seguridad, algunas áreas se consideran esenciales para la organización para garantizar sus objetivos de negocio:

- Seguridad de recursos humanos.
- Seguridad de acceso.
- Seguridad de las comunicaciones.
- Seguridad y negocios.

Tratamiento de los riesgos en la seguridad de los recursos humanos

Las personas deben ser conscientes de sus responsabilidades y los riesgos y amenazas de seguridad.

Algunas prácticas:

- Asegurar que las personas conozcan, entiendan y cumplan con sus responsabilidades en la reducción de los riesgos de seguridad de la organización.
- Las personas deben ser conscientes de que es importante notificar a sus superiores sobre cualquier evento adverso que represente riesgos (potenciales o reales) para la seguridad de la organización.
- Las personas deben conocer los posibles riesgos y amenazas de seguridad con el fin de comprender su papel en lo que se refiere a seguridad de la información en la organización.

El tratamiento del riesgo en la seguridad de acceso

- Definir los perímetros de seguridad para la seguridad física y el ambiente;
- Proteger adecuadamente los equipos contra acceso no autorizado, pérdida o daños, peligros del propio ambiente, fuga de información, entre otros;
- Evaluar si es adecuado destruir cierto dispositivo que almacena la información crítica para el negocio de la organización, o si es apropiado enviarlo para su reparación en el lugar autorizado por el fabricante del dispositivo;
- Reducir al mínimo el riesgo de corrupción de los sistemas operativos, garantizando que la actualización se lleve a cabo sólo por personas competentes y autorizadas;
- Reducir el riesgo de amenazas tales como robo, incendio, explosiones, polvo, efectos químicos, inundaciones, fallas en suministro de energía eléctrica, etc
- La educación y la sensibilización de los usuarios es fundamental para la seguridad de la información, dado que el uso adecuado de los recursos y la información, como “herramientas” de trabajo, fortalece la cultura de seguridad de la organización en conjunto.

Se recomiendan algunas prácticas:

- La restricción y monitoreo del acceso a los recursos críticos de la organización, tales como servidores, documentos, etc.;
- El uso de cifrado fuerte, asegurando la confidencialidad de la información;
- No guardar las contraseñas en los logs debido a que permite el posterior acceso de personas no autorizadas;
- Concientizar a las personas de no divulgar sus contraseñas

- Conceder acceso a las personas solamente a los recursos que son necesarios para ejecutar sus actividades.

El tratamiento de los riesgos en seguridad de las comunicaciones

- Las conexiones seguras que proporcionan servicios de red, especialmente los que operan directamente con la información crítica y las aplicaciones de negocio de la organización;
- Identificar las medidas de seguridad adecuadas para la comunicación inalámbrica, tales como autenticación fuerte y selección de frecuencias
- Establecer la revisión periódica de los derechos de acceso a la red y sus servicios, asignados a los empleados, contratistas, colaboradores etc.

El tratamiento de riesgos y el negocio

Las copias de seguridad (backups) son una herramienta importante para apoyar la continuidad de los servicios y por lo tanto el negocio.

Tratamiento para el control adecuado de la contratación de terceros:

- Definir cláusulas contractuales que responsabilicen al tercero por la seguridad.
- Definir cláusulas contractuales que permitan actualizaciones en los servicios y sistemas.

El control de la organización consta de todos los aspectos relacionados con la protección de la organización, de acuerdo con sus objetivos teniendo como base los riesgos.

Algunas recomendaciones sobre las medidas de seguridad:

- Definir las responsabilidades de los cargos de acuerdo con la jerarquía de la organización.
- Cumplir con la legislación vigente y los requisitos contractuales y reglamentarios relativos a la seguridad en la organización

Se proponen algunas medidas de seguridad para el control adecuado de los siguientes cambios:

- Documentar todos los cambios y actualizaciones realizadas y ponerlas en práctica sólo con la debida autorización;
- Evaluar el impacto de los cambios antes de implementarlos;
- Definir el procedimiento en situaciones de emergencia;
- Planificar cambios para minimizar el impacto en el día a día de la organización

La comunicación de riesgos

Esta actividad abarca todas las acciones para la divulgación de los riesgos, con el fin de informar y orientar a los participantes, buscando con ello la reducción (y, a menudo la eliminación) del riesgo en la organización.